

GAZETA: Game-Theoretic ZERo-Trust Authentication for Defense Against Lateral Movement in 5G IoT Networks

Yunfei Ge¹, Graduate Student Member, IEEE, and Quanyan Zhu², Senior Member, IEEE

Abstract—The increasing connectivity in the 5G Internet of Things networks has enlarged the attack surface and made the traditional security defense inadequate for sophisticated attackers, who can move laterally from node to node with stored credentials once build a foothold in the network. There is a need to shift from the perimeter-based defense to a zero-trust security framework that focuses on agent-centric trust evaluation and access policies to identify malicious attackers, and proactively delay their lateral movement while ensuring system performance. In this work, we propose a Game-theoretic ZERo-Trust Authentication framework, known as GAZETA, to design interdependent trust evaluation and authentication policies using dynamic game models. The stealthy and dynamic behaviors of the agent are captured by a Markov game with one-sided incomplete information. We provide a quantitative trust evaluation mechanism for the agent and update the trust score continuously based on observations. The analysis of the equilibrium not only provides a way to quantitatively assess the security posture of the network but also enables a formal method to design zero-trust authentication policies. We propose a moving-horizon computational method to enable online decisions and rapid responses to environmental changes. This online computation also enables a dynamic trust evaluation that integrates multiple sources of security evidence. We use a case study to illustrate the resilience, robustness, and efficiency of the proposed zero-trust approach.

Index Terms—Zero-trust security, lateral movement, Internet of Things, game theory, cybersecurity.

I. INTRODUCTION

WITH the recent advances in cloud services and wireless communications, the fifth-generation (5G) enabled Internet of Things (IoT) solutions have integrated various devices and computation functionalities into critical infrastructures. While such technologies increase flexibility and efficiency, they bring additional security concerns that need to be addressed. First, the increased connectivity in an IoT network inevitably enlarges the attack surface and enables the

attacker to access the system from multiple entry points [1]. Second, modern 5G IoT networks consist of heterogeneous devices, diverse applications, and third-party services, and not all of them are accompanied by regular security updates [2]. It leads to multiple vulnerabilities that can be exploited by an attacker to access the network. Moreover, the recent COVID-19 pandemic has accelerated trends such as remote work and bring your own device (BYOD), which exacerbates the need for a trustworthy 5G-enabled IoT system to provide proper authentication mechanisms for external connections from unknown or uncertain environments [3]. It becomes a challenging task to defend against all vulnerabilities and manage the security of 5G IoT networks as their size and coverage grow.

Traditional perimeter-based defense, e.g., intrusion detection and prevention [4], aims to keep the attacker outside the security perimeter. They become insufficient to defend against sophisticated adversaries, including insider threats [5] and advanced persistent threats (APTs) [6]. In these cases, the attacker can evade traditional protections, obtain privileges as an insider with stolen credentials, and move laterally in the network toward the primary target. Once attackers breach the perimeter, they will be unhindered to achieve their goals. The security in 5G IoT networks must be hardened, especially in critical infrastructures that involve public safety and sensitive information [7]. It is necessary for modern networks to transform from static and perimeter-based defenses to a zero-trust security framework that focuses on the identity and integrity of individual components in the network.

Zero trust is a new security concept that forfeits the assumption that everything behind the security perimeter is safe. It is mainly composed of two parts: policy engine (PE) and trust evaluation (TE) [8], as shown in Fig. 1. The key to zero-trust security is to establish the trust of each entity in the network. Based on the trust, the system can enforce different policies for access to network resources. However, several challenges arise from the design of zero-trust security models. First, there is a need to quantitatively define and measure the trustworthiness of the agent so that metrics can be used for planning and policy design. Second, in highly connected IoT networks, implementing verification with maximum security at all times can cause a time delay and degrade the performance of the system. Hence, strategic verification needs to be employed for the sake of balancing system performance and security. Third, the mobility and the changing topology of IoT networks create

Manuscript received 28 November 2022; revised 5 July 2023 and 2 October 2023; accepted 12 October 2023. Date of publication 23 October 2023; date of current version 22 November 2023. This work was supported in part by the National Science Foundation (NSF) under Grant ECCS-1847056 and Grant ITE-2226232, in part by Department of Energy-Office of Nuclear Energy (DOE-NE) under Grant 20-19829, and in part by the Army Research Office (ARO) under Grant W911NF-19-1-0041. The associate editor coordinating the review of this manuscript and approving it for publication was Dr. Andrew Clark. (Corresponding author: Yunfei Ge.)

The authors are with the Department of Electrical and Computer Engineering, Tandon School of Engineering, New York University, Brooklyn, NY 11201 USA (e-mail: yg2047@nyu.edu; qz494@nyu.edu).

Digital Object Identifier 10.1109/TIFS.2023.3326975

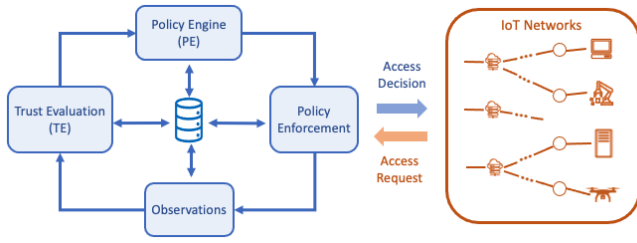


Fig. 1. GAZETA framework: An attacker moves laterally in the 5G IoT network using stolen credentials and trying to reach critical assets. The defender needs to evaluate the trust of the opponent and apply a strategic authentication policy accordingly.

a dynamic environment. Based on the baseline defense policy, the security decisions also need to accommodate the environmental change promptly and craft the policies adaptively with online learning [9]. A quantitative design framework is needed to provide a formal design methodology to address these challenges.

To formalize the zero-trust PE design, game theory has been a natural and successful framework for modeling the interactions between the system and the potential attacker. In this work, we leverage Markov games with one-sided information to design an authentication framework, called *GAme-theoretic ZERo-Trust Authentication* (GAZETA), that combats lateral movement and automates zero-trust security for 5G IoT networks. This framework provides a strategic authentication policy that takes into account the sophisticated adversarial behaviors, e.g., attack stealthiness, lateral movement, etc. [10]. Markov games model the sequential moves of the players, while one-sided information captures the nature of information asymmetry in cybersecurity. Legitimate or adversarial agents or users inside the network know their true identities and intentions, but the network defender does not and has to evaluate their trustworthiness. The autonomous GAZETA system response to access requests depends on constant monitoring of user activities and makes access decisions that are adaptive to the online situation awareness. The automation also enables cyber resilience so that the 5G IoT network can adapt to sudden changes in the agent behavior under insider threats.

In this work, the TE is estimated through dynamic Bayesian updates with multiple footprint analyses of an agent in the game. Based on the evaluated trust score of the agent, the PE can strategically conduct authentication controls that strike a balance between security and system performance. A fast and reliable TE mechanism is needed to build a resilient and low-latency defense system in 5G networks in rapidly changing environments. To accelerate trust evaluation and reduce assessment uncertainty, we have proposed a multi-source TE mechanism [11] that incorporates traditional protection methods (e.g., intrusion detection system (IDS) [12], security information and event management (SIEM) [13], etc.). The trace of the user provides a sequence of events that can be used for security analysis. By integrating reliable analytic evidence from different sources, we can identify the attacker quicker and eliminate the potential risks of a persistent attack.

With accurate trust evaluation, we can create proactive defense strategies and deter sophisticated threats such as APTs.

We hope that the proposed model can serve as an add-on service on top of the existing network infrastructure. This can be achieved by leveraging the virtualization of authentication functions through Network Function Virtualization (NFV). By deploying GAZETA as a software instance on the 5G infrastructure, the authentication process can be flexibly managed and adapted to meet evolving security needs. The equilibrium analysis of GAZETA not only provides a way to quantitatively assess the security posture of the network but also enables a formal methodology to design best-effort zero-trust policies. The optimal security policy aims to maximize the non-myopic well-being of the system by looking ahead multiple steps into the horizon. Trust evaluation supports optimal security, prioritizing effective security measures over the most accurate or least resource-intensive trust evaluation, which may still result in system vulnerabilities. Agent trust score is evaluated under a given security policy, and the optimal security policy is computed using the Bellman principle based on the trust score of an agent. The interdependency between the TE and the PE is illustrated by Fig. 1.

To circumvent the curse of dimensionality and enable online computation, we propose moving-horizon computational methods that adaptively craft the PE with online observations. This online policy engine can accommodate unanticipated changes in the environment and significantly improve cyber resilience. Based on the online policy, we utilize reliable multi-source TE to enable a fast and autonomous trust evaluation to support zero-trust security PE. We use a 5G tactical network composed of public and private sub-networks as a case study and evaluate the proposed zero-trust security solutions. We observe from the numerical experiments that GAZETA can effectively deter the adversary by increasing the number of total attack steps. The proposed framework consolidates traditional protections with zero-trust security models and provides a guide for a next-generation zero-trust framework.

The main contributions of this paper are as follows.

- We introduce GAZETA, a formal zero-trust security framework based on Markov games with one-sided information, capturing dynamic interactions between a potential attacker and the defender.
- We design a strategic authentication policy engine (PE) to efficiently deter the penetration of lateral movement while maintaining system performance.
- We formalize the concept of trust score and utilize Bayesian updates within GAZETA to perform trust evaluation. We integrate existing security protections to enable fast and autonomous trust evaluation (TE) and discuss the impact of the information's reliability.
- We propose a moving-horizon algorithm to improve cyber robustness and resilience in the face of unexpected environmental changes.
- Using a 5G-enabled IoT network as an illustrative example, we develop defense policies against lateral movement in tactical networks. Experimental results demonstrate that the proposed framework can effectively deter the

penetration of the lateral movement, adaptively adjust authentication policy to environmental changes, and provide a fast and autonomous trust evaluation with reliable evidence.

The rest of the paper is organized as follows. The related works are provided in Section II. Section III formally presents the definition of trust score. We present GAZETA in Section IV and discuss the algorithms to compute the equilibrium in Section V. A case study with numerical results is presented in Section VI. We provide a discussion in Section VII and finally conclude the paper in Section VIII.

II. RELATED WORK

Considerable efforts have been invested in research and implementation of zero-trust security. The National Institute of Standards and Technology (NIST) report [8] outlines the basic architecture and deployment of the zero-trust model. Zero-trust security has been applied to enterprise security (e.g., Google BeyondCorp [14]), cloud computing security [15], big data [16], etc. Despite the extensive applications, these zero-trust approaches often categorize the agents or services into different trust levels based on the checking of predefined rules, lacking formal modeling and quantitative definitions to continuously assess the trust in the system.

In the field of IoT security and trust management, several studies have aimed to enhance security using different approaches. Xiao et al. [17] have conducted an extensive exploration of machine learning based solutions for IoT networks. Saied et al. [18] have introduced a centralized context-aware trust management system in IoT to select capable devices and defend against trust-related attacks. However, the work lacks a zero-trust perspective and assumes that all nodes are trustworthy at the beginning. Samaniego and Deters [19] have proposed a distributed blockchain-based middleware that utilizes a hierarchical structure in IoT systems to validate the infrastructure and access transactions at different levels of trust. While the work takes the zero-trust concept into account, there is no quantitative metric to measure the trust of each entity in the network. Our work addresses these limitations by providing a quantitative and continuous trust evaluation mechanism to support an efficient zero-trust policy.

Authentication is a critical aspect of security in 5G-enabled IoT networks. These networks typically rely on static authentication methods that establish trust based on single pieces of evidence. For example, 5G-AKA (authentication and key agreement) uses shared symmetric keys [20], and EAP-TLS (Transport Layer Security) relies on digital public key certificates for user-to-network authentication [21]. Ni et al. [22] introduced a service-oriented authentication framework designed to support network slicing for 5G-enabled IoT applications. Jia et al. [23] proposed a decentralized authentication model leveraging blockchain technology. However, these authentication methods often employ a binary trust model and do not consider the behavior model of potential attackers or their past interactions. This limitation becomes particularly relevant in long-term dynamic environments like 5G IoT, where sophisticated attacks can pose significant security challenges.

Lateral movement is a critical aspect of APTs that warrants our attention. For lateral movement detection, Bowman et al. [24] have applied an unsupervised graph-based machine learning pipeline to detect malicious lateral movement from authentication logs. The authors in [25] have established a tripartite graph framework to model the interactions between agents, machines, and applications. They adopt a global perspective and propose a set of defense actions regarding graph connectivity to ensure system resilience. Nouredine et al. in [26] have presented a game-theoretic automatic response engine against a specific attacker with lateral movement. However, these approaches assume a static network topology and trusted normal agents. Our approach provides a strategic authentication policy to mitigate lateral movement and offers an adaptive learning-based defense mechanism based on the trust of the agents.

Modern 5G IoT systems face a variety of security threats [27]. It is critical to consolidate security into the system design, especially for mission-critical applications which rely on a safe and dependable operational environment. The hybrid architecture of public and tactical 5G IoT networks requires constant trust evaluation of the network components. Suomalainen et al. [7] have addressed the security of 5G public safety communication, which utilizes both tactical bubbles and commercial operators' infrastructure. Ramezanpour and Jagannath [28] have proposed a zero-trust architecture for 5G networks utilizing artificial intelligence to provide information security in untrusted networks, which requires a lot of training data. This work contributes to this body of literature and focuses on designing zero-trust defenses against lateral movement using game-theoretic approaches. Our framework is broadly applicable to many other networks of similar nature.

III. TRUST SCORE

One key component of the zero-trust security model is the trust evaluation mechanism, which adopts a metric to measure the trustworthiness of an agent and provide risk analysis for policy decisions [29], [30]. In this work, we refer to this metric as *trust score* (TS). We formalize the trust score of an agent as the probability that he is non-adversarial to the system. Suppose the agent in the system can be categorized into different types $\theta \in \Theta = \{0, 1, \dots, N\}$, where type $\theta = 0$ represents a legitimate user, and other types $\theta \neq 0$ represent the adversarial insiders or attackers with different strategies. Formally, the trust score of the agent can be defined as follows.

Definition 1 (Trust Score): Trust Score (TS) is a metric to evaluate the trustworthiness of an agent in the network. The TS of agent i is defined as the probability that agent i is non-adversarial to the system, i.e., $\theta_i = 0$:

$$TS_i := \Pr[\theta_i = 0]. \quad (1)$$

In our framework, the evaluated TS_i will be updated dynamically during the interactions with the agent. In general, if the agent conducts any abnormal behavior, the trust score will decrease. Let TS_i^* denote the true trust score of the agent. For a binary type set, $TS_i^* = 1$ if the agent is legitimate with

$\theta_i = 0$, otherwise $TS_i^* = 0$. The goal of the trust evaluation mechanism is to provide a TS_i that is closer to TS_i^* for any agent i . It should be noted that in this work, we solely focus on the trustworthiness regarding agent's identity. In practice, trust is multifaceted and the type θ can be extended to a vector where each entry represents different trust attributes.

IV. GAZETA GAME MODEL

In this section, we formally introduce the game-theoretic zero-trust authentication (GAZETA) framework. GAZETA consists of two players, a defender (she), which is the network security management system, and an agent (he), who can be legitimate or adversarial. Consider that the agent logs in to the system at some node and attempts to access a specific sensitive target node in the network. This target is typically the database, an application server, or critical user equipment in the 5G IoT system. Based on the zero-trust assumption, whether the agent is legitimate or malicious is uncertain to the defender in the beginning. The defender needs to determine the authentication and access policies strategically so that it can protect valuable assets while ensuring system performance. During the interactions, the defender needs to learn the agent's TS and adapt security policies accordingly. Our primary objective is to ensure system's performance with a legitimate user while delaying the lateral movement against a potential attacker.

A. Authentication Graph

We first introduce the basic environment of the game. We use a directed authentication graph to describe the network-level authentication activities and reachability of the agent.

Definition 2 (Authentication Graph): An agent-specific authentication graph is a directed graph $G = \langle V, E \rangle$, where V is the set of nodes in an IoT network (e.g., servers, applications, user equipment) and $E \subseteq \{(u, v) \mid u, v \in V \text{ and } u \neq v\}$ is a set of directed edges representing the past authentication connections of the agent from node u to node v .

The authentication graph serves as a visual representation of an agent's activity and authentication behaviors within a system. The information is intended only for legitimate users with authorized access. However, this sensitive information can be exposed to malicious attackers through various threat models such as insider threats or credential theft. Attackers may gain access to the authentication graph if legitimate users unintentionally or intentionally share knowledge with malicious entities. Alternatively, attackers can acquire this data by extracting information from event logs stored in the Authentication, Authorization, and Accounting (AAA) server within the 5G IoT network. Analyzing these logs allows attackers to comprehend the authentication graph, potentially using it for malicious purposes.

In this work, we assume that if the agent has visited node u , he can utilize the stored credentials at node u to move toward node v through link $(u, v) \in E$. In practice network scenarios, authentication protocols such as Kerberos [31] and

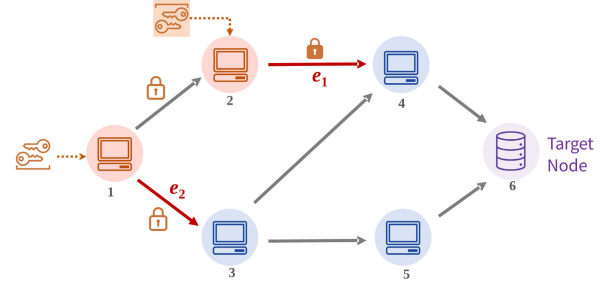


Fig. 2. Example of an authentication graph with node labels. The agent can move to the unvisited nodes (blue) using stored credentials at the visited nodes (red) to reach the target node (purple).

OAuth 2.0 [32] are commonly employed. To gain access, an agent, whether legitimate or an attacker, must provide the correct password to the AAA server. Legitimate users provide the password they have defined, while attackers may attempt to capture locally stored password hashes and utilize them for authentication and subsequent lateral movement. This technique is commonly referred to as “Pass-the-Hash”. Attackers often acquire password hashes by extracting data from a system's active memory. By monitoring logon events or processes that seek user credentials, we can employ the following label function to describe the nodes visited within the network.

Definition 3 (Label Function): Given the current agent-specific authentication graph $G^k = \langle V^k, E^k \rangle$ and logon events up to time k , the node label function $L^k : V^k \mapsto \{0, 1\}$ is an indicator function defined over all nodes in the authentication graph. For any node $v \in V^k$,

$$L^k(v) = \begin{cases} 1 & \text{if } v \text{ has been visited,} \\ 0 & \text{otherwise.} \end{cases} \quad (2)$$

Fig. 2 illustrates an example of a directed authentication graph with colored node labels. Labeling the nodes on the graph allows us to observe the potential communication chains that could be used by the malicious attacker to spread his access within the network.

It is important to note that a cyclic authentication graph can exist without influencing the performance of the model. When a cycle does not have access to the target, there is no incentive for an attacker to compromise the nodes within that cycle. On the other hand, if the cycle contains access to the target, there is no benefit for the attacker to attack the nodes in the cycle that have already been compromised, as per the defined action in subsequent sections. In either scenario, the framework will continue to function effectively.

B. Markov Game With One-Sided Information

The GAZETA framework builds on a two-person general-sum Markov game with one-sided information. In this game, the agent possesses complete access to the game information, while the defender remains unaware of the agent's true type. The game unfolds in discrete time, progressing through stages denoted by $k = 0, 1, \dots, K$. At stage $k = 0$, the agent logs into the system at the initial node set $\hat{V}$. This means that the label $L^0(v)$ is set to 1 for all nodes v in $\hat{V}$, and 0 for all

other nodes v in V^0 excluding $\hat{V}$. The game components are as follows.

- **Players** $i \in \{a, d\}$: Two players interact in the game. P_a is the agent who attempts to reach the target node, while P_d is the defender who controls the zero-trust access policies. A binary type set $\Theta = \{0, 1\}$ is considered for the agent P_a , where $\theta = 0$ is legitimate user and $\theta = 1$ represents adversarial attacker. The type θ is the private information only available for the agent P_a .
- **Game State** S^k : The game state at stage k is a tuple $s^k = \langle G^k, L^k \rangle \in S^k$, where $G^k = \langle V^k, E^k \rangle$ is the current authentication graph and L^k contains the labels obtained from (2) for all nodes $v \in V^k$ at stage k . We denote the total possible game states at stage k as a finite set S^k .
- **Agent's action set** A^k : At each stage, the agent attempts to access the next node using the stored credentials in the visited nodes. The directed edges in the authentication graph represent the possible moves if the agent is authenticated and fully trustworthy. Given the game state s^k , the possible actions of the agent is a set of edges such that the tail node u is visited while the head node v is not.

$$A^k = \{(u, v) | (u, v) \in E^k, L^k(u) = 1, L^k(v) = 0\} \subseteq E^k \quad (3)$$

The edges $\{e_1, e_2\}$ in Fig. 2 form the agent's action set A^k in the example. Without loss of generality, we assume that the agent only sends one access request $a^k \in A^k$ at each stage. This assumption aligns with the stealthiness of APT attackers since they intend to avoid detection and keep a low profile.

- **Defender's action set** D^k : The defender aims to validate the authentication of the agent and reject potential lateral movement from malicious attackers. The identity validation may require alternative authentications (e.g., Multi-factor Authentication (MFA) [33]) that would create difficulty for the attacker with only stored credentials. However, this additional authentication process is resource- and time-consuming. The identity validation over the edge $e \in E$ has an associated cost given by the cost function $C : E \mapsto \mathbb{R}_+$. The defender needs to discover attacks while minimizing resource consumption for the sake of balancing system performance and security. Thus, we assume that the defender can strategically pick a set of edges for authentication validation. Given the game state s^k , we let $P(A^k)$ denote the set of all possible subsets of A^k . The defender's action set at stage k is $D^k := P(A^k)$ with cardinality $2^{|A^k|}$.
- **Transition Kernel** $T : S^k \times A^k \times D^k \times \Theta \mapsto \Delta(S^{k+1})$: Given the current state s^k and the type of the agent θ , the joint action pair (a^k, d^k) decides the next game state s^{k+1} , where $a^k \in A^k$ and $d^k \in D^k$. If $a^k \in d^k$, the agent needs to satisfy the validation requirements before he obtains access permission. We assume that legitimate user ($\theta = 0$) can pass this additional authentication process with a high probability while malicious attacker

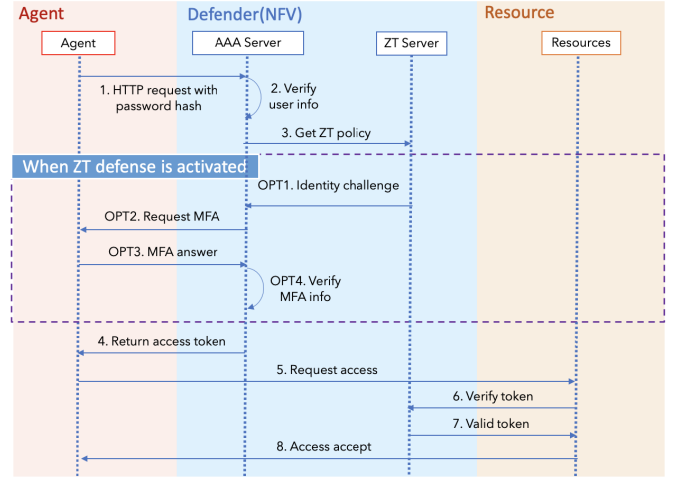


Fig. 3. Illustration of the authentication process on one edge. The attacker with password hashes attempts to pass the user verification at the AAA server. The ZT defender decides whether to request additional authentication validation (OPT1 to OPT4) based on current trust evaluation of the agent. If requested, the attacker may need to provide further proof of identity, such as MFA. Once the authentication is validated, the defender allows access to the requested resource.

($\theta = 1$) has a higher chance of rejection. If $a^k \notin d^k$, both types of agents can successfully move forward. s^{k+1} is updated accordingly based on the label function and network topology at the next stage.

Fig. 3 illustrates the authentication process on a particular edge. In this process, additional authentication validation is triggered if the action a^k of the agent is included in the set d^k . The set d^k is determined by the Zero Trust (ZT) server, which evaluates the trustworthiness of the agent. If the agent reaches the target node, it remains in the target node until the termination of the game.

- **Utility functions** $R_i : S^k \times A^k \times D^k \times \Theta \rightarrow \mathbb{R}$: At each stage k , given the agent type θ , the function $R_i(s^k, a^k, d^k, \theta)$ defines the payoff of an action pair (a^k, d^k) at state s^k for each player $i \in \{a, d\}$. We define the utility functions as follows.

- Scenario 1: the agent is a legitimate user with $\theta = 0$. If the user chooses to send access request via edge $a^k = (x, y) \in A^k$ and the defender chooses to conduct additional validation over edge(s) $d^k \in D^k$ at state s^k , then

$$R_a(s^k, a^k, d^k, 0) = \begin{cases} u_0(s^k, y) - \hat{m} & \text{if } a^k \in d^k, \\ u_0(s^k, y) & \text{otherwise,} \end{cases}$$

$$R_d(s^k, a^k, d^k, 0) = -C^p(d^k) = -\sum_{e \in d^k} C(e), \quad (4)$$

where $u_0(s^k, y)$ denotes the benefit of accessing node y at the current state s^k for the legitimate user. Machine learning can identify typical behaviors of the legitimate user and help to design the utility functions [34]. $\hat{m} \in \mathbb{R}_+$ is a relatively small cost for the legitimate user to complete additional authentication and verify his identity. Function $C^p : D^k \mapsto \mathbb{R}_+$ is the total cost of authentication validation, which

TABLE I
GAME MATRIX UNDER LEGITIMATE USER $\theta = 0$

User Action	Defense Action	
	$e_1 : (2, 4)$	$e_2 : (1, 3)$
$e_1 : (2, 4)$	$(u_0(s, 4) - \hat{m}, -C(e_1))$	$(u_0(s, 4), -C(e_2))$
$e_2 : (1, 3)$	$(u_0(s, 3), -C(e_1))$	$(u_0(s, 3) - \hat{m}, -C(e_2))$

TABLE II
GAME MATRIX UNDER ATTACKER $\theta = 1$

Attacker Action	Defense Action	
	$e_1 : (2, 4)$	$e_2 : (1, 3)$
$e_1 : (2, 4)$	$(-\hat{M}, \hat{M} - C(e_1))$	$(u_1(s, 4) - w(e_1), -u_1(s, 4) + w(e_1) - C(e_2))$
$e_2 : (1, 3)$	$(u_1(s, 3) - w(e_2), -u_1(s, 3) + w(e_2) - C(e_1))$	$(-\hat{M}, \hat{M} - C(e_2))$

captures the time delay and influence of system performance.

- Scenario 2: the agent is an adversarial attacker with $\theta = 1$.

$$R_a(s^k, a^k, d^k, 1) = \begin{cases} -\hat{M} & \text{if } a^k \in d^k, \\ u_1(s^k, y) - w(a^k) & \text{otherwise,} \end{cases}$$

$$R_d(s^k, a^k, d^k, 1) = -R_a(s^k, a^k, d^k, 1) - C^p(d^k), \quad (5)$$

where $u_1(s^k, y)$ denotes the benefit of accessing node y at current state for the attacker, and $\hat{M} \in \mathbb{R}_+$ is the cost of being inspected if the defender conducts validation over a^k . This value can be regarded as the cost of rejection or the extra effort to pass the validation. Thus, we assume that $\hat{M}$ is a relatively large value. Function $w : A^k \mapsto \mathbb{R}$ is the cost of attack effort over the chosen edge. The payoff for the defender is the opposite of the attacker plus the total cost of authentication validation.

Tables I and II present the payoff matrices of the example in Fig. 2. For illustration purposes, we assume that the defender inspects only one edge at each stage. For each matrix entry, the first element is $R_a(\cdot)$ and the second element is $R_d(\cdot)$.

- **Game horizon K :** The finite game horizon $K \in (0, \infty)$ represents the maximum time span for the agent to exist in the network without credential renewal. The stored credentials can expire due to their maximum identity lifetime. The security administrator can also force the agent to leave due to security investigations. After horizon K , the system removes all stored credentials of the agent and asks him to log in again. The attacker will lose his foothold in the network if he cannot reach the target within K steps.

C. Strategies and Trust Update

The authentication strategies of the defender depend on the type of agent. However, the type is unrevealed to the defender, and thus she has to make decisions based on her belief about

the agent's type. For instance, if the agent is non-adversarial, the defender can apply any authentication strategies with the least cost to ensure system performance. However, if the agent is malicious, the defender needs to conduct a strategic authentication validation to identify the attacker efficiently.

To tailor the strategy against a specific opponent, the players can use any available information up to the decision-making time. This type of strategy is called *behavior strategy*. In this work, we consider Markov (mixed) strategy, which is a special case of behavior strategy, for both players.

Definition 4 (Player's strategies): Given the current state $s^k \in S^k$, the agent type θ , and the set of possible actions A^k and D^k , a Markov strategy $\pi_a^k(\cdot | s^k, \theta)$ of the agent is defined as

$$\pi_a^k : S^k \times \Theta \mapsto \Delta(A^k) \quad \forall k = 0, 1, \dots, K-1, \quad (6)$$

and the Markov strategy $\pi_d^k(\cdot | s^k)$ of the defender is

$$\pi_d^k : S^k \mapsto \Delta(D^k) \quad \forall k = 0, 1, \dots, K-1. \quad (7)$$

Note that the model is a game with one-sided incomplete information. The agent knows his true type θ , but the defender does not. The defender needs to infer the true type and form a belief $b^k \in \Delta(\Theta)$ from the past interactions. This belief measures the trustworthiness of the agent and can be used as the trust score in the zero-trust architecture. In the following sections, we use the terms *belief* and *trust* interchangeably.

We assume that when the agent first logs into the IoT system, the defender establishes an initial trust with TS^0 . It corresponds to the prior belief $b^0 = [TS^0, 1 - TS^0]$ in the Markov game literature. The initial trust is common knowledge for both players. The defender can carry out risk analysis from historical data or compare the attributes of the agent with a set of predefined rules to obtain TS^0 . Then, at each stage k , the belief b^{k+1} can be updated with the Bayesian rule.

(Ex-ante) Trust Update: for each type $\theta \in \Theta$, as (8), shown at the bottom of the next page.

If the denominator equals 0, we let $b^{k+1}(\theta | s^{k+1}) = b^0(\theta)$. This is an *ex-ante* belief update in the planning phase. For stage k and game state s^k , the relationship between the trust score and the belief is

$$TS^k = b^k(\theta = 0 | s^k). \quad (9)$$

V. EQUILIBRIUM COMPUTATION

Under the Markov game framework, both players aim to maximize their expected cumulative utility within the finite horizon. According to the aforementioned game model, the immediate utility at each state s^k depends on the joint action pair (a^k, d^k) . It indicates that the expected cumulative utility relies on the strategies of both players. Starting from $s^0 \in S^0$, given the initial belief b^0 , the type $\theta \in \Theta$, and the strategy profile of both players $\Pi_i = [\pi_i^0, \dots, \pi_i^K]$, $i \in \{a, d\}$, the expected cumulative utility of the agent is

$$\bar{U}_a(s^0, \Pi_a, \Pi_d, \theta) = \mathbb{E}_{\Pi_a, \Pi_d} \left[\sum_{k=0}^K R_a^k(s^k, a^k, d^k, \theta) \right], \quad (10)$$

and the expected cumulative utility of the defender is

$$\bar{U}_d(s^0, \Pi_a, \Pi_d, b^0) = \mathbb{E}_{\Pi_a, \Pi_d, B} \left[\sum_{k=0}^K R_d^k(s^k, a^k, d^k, \theta) \right], \quad (11)$$

where $B = [b^0, \dots, b^K]$ is a sequence of beliefs updated using (8). Since the defender does not know the true type θ of the agent, she needs to take the expectation of utility functions with respect to θ at each stage.

In this work, we consider one-sided ϵ -Perfect Bayesian Nash Equilibrium (ϵ -PBNE) as the solution concept. Formally,

Definition 5 (One-Sided ϵ -PBNE): For a given real value $\epsilon \geq 0$, a strategy profile (Π_a^*, Π_d^*) is called a one-sided ϵ -Perfect Bayesian Nash Equilibrium (ϵ -PBNE) if the following two conditions hold.

(SR) **Sequential Rationality:** For any stage $k \in \{0, 1, \dots, K\}$ and state $s^k \in S^k$, given the belief b^k , each strategy profile $\Pi_i^{*,k:K} = [\pi_i^{*,k}, \dots, \pi_i^{*,K}]$, $i \in \{a, d\}$ should be ϵ -optimal in expectation.

$$\begin{aligned} & \bar{U}_a(s^k, \Pi_a^{*,k:K}, \Pi_d^{*,k:K}, \theta) + \epsilon \\ & \geq \bar{U}_a(s^k, \Pi_a^{k:K}, \Pi_d^{*,k:K}, \theta) \quad \forall \Pi_a^{k:K} \in \Pi_a^{k:K}, \quad \forall \theta \in \Theta, \\ & \bar{U}_d(s^k, \Pi_a^{*,k:K}, \Pi_d^{*,k:K}, b^k) + \epsilon \\ & \geq \bar{U}_d(s^k, \Pi_a^{*,k:K}, \Pi_d^{k:K}, b^k) \quad \forall \Pi_d^{k:K} \in \Pi_d^{k:K}, \end{aligned} \quad (12)$$

where $\Pi_i^{k:K}$ contains all possible strategy profiles for player $i \in \{a, d\}$ from stage k to K .

(BC) **Belief Consistency:** Under ϵ -optimal strategies, the belief at each stage should be updated using Bayes' rule in (8).

ϵ -PBNE provides an approximated solution of Perfect Bayesian Nash Equilibrium (PBNE). If we set $\epsilon = 0$, we obtain an exact PBNE.

A. One-Sided ϵ -PBNE Algorithm

To solve the game, we first define the value function for the players. The value function estimates the future expected utilities for the player to be in a given state. Given Π_a , Π_d and B , when at stage k and game state s^k , the value function of the agent is $V_a^k(s, \theta) := \bar{U}_a(s^k, \Pi_a^{k:K}, \Pi_d^{k:K}, \theta)$, and defender's value function is $V_d^k(s) := \bar{U}_d(s^k, \Pi_a^{k:K}, \Pi_d^{k:K}, b^k)$. Using the value functions, we can apply dynamic programming and backward induction to find the one-sided ϵ -PBNE. Inspired by [10], we provide a modified algorithm to solve the Markov game with one-sided incomplete information.

At the final stage K , we can form the following optimization program to solve the one-stage game for both players. Given the state s^K and belief $b = b^K$, the optimal strategy pair

$(\pi_a^{*,K}, \pi_d^{*,K})$ can be computed by solving

$$\begin{aligned} & \min_{\pi_a, \pi_d, h_a, h_d} \sum_{\theta} \alpha_{\theta} \left[h_a(s^K, \theta) - \mathbb{E}_{\pi_a, \pi_d} [R_a(s^K, a, d, \theta)] \right] \\ & \quad + h_d(s^K) - \mathbb{E}_{\pi_a, \pi_d, b} [R_d(s^K, a, d, \theta)] \\ & \text{s.t. } \mathbb{E}_{\pi_d} [R_a(s^K, a, d, \theta)] \leq h_a(s^K, \theta) \quad \forall a \in A^K, \quad \forall \theta \in \Theta \\ & \quad \mathbb{E}_{\pi_a, b} [R_d(s^K, a, d, \theta)] \leq h_d(s^K) \quad \forall d \in D^K \\ & \quad \sum_{a \in A^K} \pi_a(a|s^K, \theta) = 1, \quad \pi_a(a|s^K, \theta) \geq 0 \\ & \quad \forall a \in A^K, \quad \forall \theta \in \Theta \\ & \quad \sum_{d \in D^K} \pi_d(d|s^K) = 1, \quad \pi_d(d|s^K) \geq 0 \quad \forall d \in D^K \end{aligned} \quad (13)$$

The solutions provide the values of the game $V_a^K(s^K, \theta) = h_a^*(s^K, \theta)$, $V_d^K(s^K) = h_d^*(s^K)$, and optimal strategy pair $(\pi_a^{*,K}, \pi_d^{*,K})$ for the players at last stage. The first two constraints ensure that the expected maximum utilities of the players are equivalent to their value functions, respectively. The remaining constraints guarantee that $\pi_d(\cdot)$ and $\pi_a(\cdot)$ are probability measures over the action spaces, respectively. The type-dependent weights $\{\alpha_{\theta}\}_{\theta \in \Theta}$ satisfy $\alpha_{\theta} \geq 0, \forall \theta \in \Theta$ and $\sum_{\theta \in \Theta} \alpha_{\theta} = 1$.

At stage $k < K$, we can solve the game using backward induction. Given the state s^k , belief $b = b^k$, and the value functions of the next stage V_i^{k+1} , the optimal strategy pair $(\pi_a^{*,k}, \pi_d^{*,k})$ can be computed by solving

$$\begin{aligned} & \min_{\pi_a, \pi_d, h_a, h_d} \sum_{\theta} \alpha_{\theta} h_a(s^k, \theta) \\ & \quad - \sum_{\theta} \alpha_{\theta} \mathbb{E}_{\pi_a, \pi_d} \left[R_a(s^k, a, d, \theta) + V_a^{k+1}(s^{k+1}, \theta) \right] \\ & \quad + h_d(s^k) - \mathbb{E}_{\pi_a, \pi_d, b} \left[R_d(s^k, a, d, \theta) + V_d^{k+1}(s^{k+1}) \right] \\ & \text{s.t. } \mathbb{E}_{\pi_d} \left[R_a(s^k, a, d, \theta) + V_a^{k+1}(s^{k+1}, \theta) \right] \leq h_a(s^k, \theta) \\ & \quad \forall a \in A^k, \quad \forall \theta \in \Theta \\ & \quad \mathbb{E}_{\pi_a, b} \left[R_d(s^k, a, d, \theta) + V_d^{k+1}(s^{k+1}) \right] \leq h_d(s^k) \\ & \quad \forall d \in D^k \\ & \quad \sum_{a \in A^k} \pi_a(a|s^k, \theta) = 1, \quad \pi_a(a|s^k, \theta) \geq 0 \\ & \quad \forall a \in A^k, \quad \forall \theta \in \Theta \\ & \quad \sum_{d \in D^k} \pi_d(d|s^k) = 1, \quad \pi_d(d|s^k) \geq 0 \quad \forall d \in D^k \end{aligned} \quad (14)$$

Similarly, the solutions provide the values of the game $V_a^k(s^k, \theta) = h_a^*(s^k, \theta)$, $V_d^k(s^k) = h_d^*(s^k)$, and optimal strategy pair $(\pi_a^{*,k}, \pi_d^{*,k})$ at stage k . Note that here we omit the transition function $T(s^{k+1}|s^k, a, d)$, and s^{k+1} is a function of T .

$$b^{k+1}(\theta|s^{k+1}) = \frac{\sum_{a \in A^k, d \in D^k} T(s^{k+1}|s^k, a, d, \theta) \pi_a^k(a|s^k, \theta) \pi_d^k(d|s^k) b^k(\theta|s^k)}{\sum_{a \in A^k, d \in D^k, \hat{\theta} \in \Theta} T(s^{k+1}|s^k, a, d, \hat{\theta}) \pi_a^k(a|s^k, \hat{\theta}) \pi_d^k(d|s^k) b^k(\hat{\theta}|s^k)}. \quad (8)$$

Algorithm 1 GAZETA ϵ -PBNE Computation

Input: Prior belief b^0 , threshold $\epsilon \geq 0$.
Initialization: set $b^k = b^0, \forall k \in \{0, 1, \dots, K\}$;
while (SR) and (BC) are not satisfied **do**
 Given beliefs b^k , for all s^K , compute (π_a^K, π_d^K)
 by solving (13);
 for $k \leftarrow K - 1$ **to** 0 **do**
 Given beliefs b^k , for all s^k , compute (π_a^k, π_d^k)
 by solving (14);
 for $k \leftarrow 0$ **to** K **do**
 Given computed strategies (Π_a, Π_d) , update
 beliefs at each stage b^k using (8);
Output: Optimal strategies (Π_a^*, Π_d^*) and consistent
belief sequence B .

Theorem 1: Given the belief sequence $B = [b^0, \dots, b^K]$, the optimal strategy profile (Π_a^*, Π_d^*) provided by the solutions to optimization problems (13) and (14) satisfy the (SR) constraint with $\epsilon = 0$ and constitute a one-sided Dynamic Bayesian Nash Equilibrium (DBNE).

Proof: We first show that the solution to (13) provides a one-sided Bayesian Nash Equilibrium (BNE) at the last stage. Given the BNE pair $(\pi_a^{*,K}, \pi_d^{*,K})$ and game values (V_a^K, V_d^K) , $(\pi_a^{*,K}, \pi_d^{*,K}, h_a = V_a^K, h_d = V_d^K)$ is feasible to (13) as they satisfy all the constraints. The first two constraints are satisfied as equality constraints at $h_a = V_a^K$ and $h_d = V_d^K$. Since the objective is non-negative under the first two constraints, the solution is optimal as the objective achieves the minimum value 0. On the other hand, if (π_a, π_d, h_a, h_d) is the optimal solution to (13), it should satisfy the one-stage rationality constraint similar to (12) with $k = K$, $\pi_a^{*,K} = \pi_a$, $\pi_d^{*,K} = \pi_d$, $\bar{U}_a = V_a^K = h_a$, and $\bar{U}_d = V_d^K = h_d$. Thus, the solution to (13) is equivalent to a BNE. Then, we can further prove that the sequence of solutions to (13) and (14) are DBNE following a similar argument in a backward order. $\square$

Based on Theorem 1, given the belief sequence B , we can find the optimal policies (Π_a^*, Π_d^*) that satisfy (SR) constraints. However, in order to find one-sided ϵ -PBNE, the belief sequence needs to be consistent as required by (BC) constraints. In this work, we provide an approximation approach to find the one-sided ϵ -PBNE by iteratively alternating between the forward belief update and the backward policy computation. The complete GAZETA ϵ -PBNE algorithm is given in Algorithm 1. We assume that the initial beliefs at each stage are the same as the prior belief. After solving the strategies backward for $k : K \rightarrow 0$ using the given belief sequence, we update the beliefs forward for $k : 0 \rightarrow K$ and obtain the new belief sequence. The procedure is repeated until both (SR) and (BC) are satisfied. Thereby we obtain the one-sided ϵ -PBNE.

The computational complexity of the algorithm can be high for large networks. Depending on the network topology, the number of possible states grows exponentially as a function of time k [35]. However, an advantage is that the ϵ -PBNE can be computed offline for various initial conditions. This allows

Algorithm 2 GAZETA With Moving-Horizon Defense

Input: Computational time span $\hat{k} < K$; prior belief b^0 ; threshold $\epsilon > 0$.
Initialization: $k = 0, s^k = s^0$ and $b^k = b^0$;
while $k < K$ **do**
 Compute optimal strategies with $\hat{k}$ -steps ahead
 using Algorithm 1;
 Take one step forward using the computed
 strategies, $(a^k, d^k) \sim \pi_a^{*,k}, \pi_d^{*,k}$;
 Observe s^{k+1} and update the belief via (15);
 $k \leftarrow k + 1, s^k \leftarrow s^{k+1}, b^k \leftarrow b^{k+1}$;

for direct retrieval during real implementation, mitigating the need for extensive computations in real-time.

B. Moving-Horizon Defense

One drawback of the aforementioned computational method is the curse of dimensionality. Furthermore, the IoT network is a dynamic environment that can change frequently. The dynamic environment creates additional constraints for GAZETA. The strategies need to be recomputed even with a slight change in the environment. To address this issue, we propose a moving-horizon defense scheme by computing and adapting the defense mechanisms online.

At each state k , the players select a short time span $\hat{k} < K$ and determine the action to take at k by looking into the $\hat{k}$ steps into the future and computing the equilibrium strategies for the finite one-sided Markov game using Algorithm 1. The players implement the first step of the computed policy using the obtained strategies, $(a^k, d^k) \sim (\pi_a^{*,k}, \pi_d^{*,k})$. The system moves to a new state s^{k+1} after the two players take their actions. The defender updates the belief using the following equation once she observes the state.

(Ex-post) Trust Update: for each type $\theta \in \Theta$, as (15), shown at the bottom of the next page.

This is an *ex-post* trust update computed after action execution and state transition. This updated belief serves the prior belief for the next round. The complete process of the moving-horizon defense scheme is described in Algorithm 2. In practice, we can restrict our computation to all reachable states from s^k with $\hat{k}$ -steps ahead. This allows us to reduce the state space and compute the strategies more efficiently.

Algorithm 1 generates the full horizon offline-computed defense policy, which acts as the baseline of zero-trust security in the environment. Moving-horizon defense helps the players accommodate environmental changes during online decision-making. Algorithm 2 provides an online way to plan for strategic authentication validation that is more computationally efficient and robust.

C. Trust Update With Multi-Source Evidence

To achieve a fast and accurate trust evaluation, the defender can incorporate additional sources of evidence during trust updates. For instance, Intrusion Detection Systems (IDS) [12] can generate security alerts when abnormal behaviors occur. Security Information and Event Management (SIEM) systems

can collect, aggregate, and analyze event data across the enterprise to provide security reports [13]. The organization can also refer to commercial threat intelligence to provide third-party trust evaluation. Reliable information can help the defender obtain a more accurate trust score and adapt corresponding strategies.

In this work, we assume that the external evidence is additional information taking binary value $h \in H = \{0, 1\}$, where $h = 1$ indicates a security alarm, and $h = 0$ means no alarm. The security alarm warns the defender when the agent is more likely to be malicious. The evidence space H can be further extended based on the output of the evidence generator. In the binary case, each evidence generator is associated with an evidence probability function defined as follows.

Definition 6 (Evidence probability function): For evidence $h \in H = \{0, 1\}$, the evidence probability function σ is defined as $\sigma : S^k \times A^k \times \Theta \mapsto \Delta(H)$, which indicates the probability of generating evidence h based on observed state s^k and agent action a^k .

The evidence probability function is given by the evidence provider and how to obtain it is beyond the scope of this work. In general, the evidence is generated based on the probability that the agent with type θ takes action a^k at s^k . Observing the evidence h , the defender can further update the *ex-post* trust as follows.

(Ex-post) Trust Update with Evidence: for each type $\theta \in \Theta$,

$$\begin{aligned} & \hat{b}^{k+1}(\theta|s^{k+1}, a^k, d^k, h) \\ &= \frac{\sigma(h|s^k, a^k, \theta)b^{k+1}(\theta|s^{k+1}, a^k, d^k)}{\sum_{\hat{\theta} \in \Theta} \sigma(h|s^k, a^k, \hat{\theta})b^{k+1}(\hat{\theta}|s^{k+1}, a^k, d^k)}, \end{aligned} \quad (16)$$

where $b^{k+1}(\theta|s^{k+1}, a^k, d^k)$ is the *ex-post* trust computed according to (15).

In practice, there exist multiple sources of evidence with evidence probability function $(\sigma_1, \dots, \sigma_n)$. The defender can incorporate the evidence in sequential order. Suppose the trust update including evidence $(h_1, \dots, h_j)$ is $\hat{b}^{k+1}(\theta|s^{k+1}, a^k, d^k, h^{1:j})$, where each $h_j \sim \sigma_j$. The defender can further update the trust with evidence h_{j+1} by

$$\begin{aligned} & \hat{b}^{k+1}(\theta|s^{k+1}, a^k, d^k, h^{1:j+1}) \\ &= \frac{\sigma_{j+1}(h_{j+1}|s^k, a^k, \theta)\hat{b}^{k+1}(\theta|s^{k+1}, a^k, d^k, h^{1:j})}{\sum_{\hat{\theta} \in \Theta} \sigma_{j+1}(h_{j+1}|s^k, a^k, \hat{\theta})\hat{b}^{k+1}(\hat{\theta}|s^{k+1}, a^k, d^k, h^{1:j})}. \end{aligned} \quad (17)$$

Ideally, the trust update with evidence emits a trust score closer to TS^* . To achieve this, the defender needs to ensure the reliability of the external evidence when incorporating this additional information. The quality of the evidence function can be characterized by the true-positive rate $P_t \in [0, 1]$ and false-positive rate $P_f \in [0, 1]$. These values are typically

determined by the external evidence generator, and there are no specific restrictions on their ranges. For the sake of simplicity in this work, we assume that the evidence function has the same true-positive rate and the same false-positive rate under both types of agents, i.e., for each $k = 1, \dots, K$,

$$\begin{aligned} P_t(s^k, a^k) &= \sigma(h = 1|s^k, a^k, \theta = 1) = \sigma(h = 0|s^k, a^k, \theta = 0) \\ &\quad \forall s^k \in S^k, a^k \in A^k, \end{aligned} \quad (18)$$

$$\begin{aligned} P_f(s^k, a^k) &= \sigma(h = 0|s^k, a^k, \theta = 1) = \sigma(h = 1|s^k, a^k, \theta = 0) \\ &\quad \forall s^k \in S^k, a^k \in A^k. \end{aligned} \quad (19)$$

Theorem 2: Given current state s^k and agent's action a^k , a reliable external evidence should satisfy $P_t(s^k, a^k) \geq P_f(s^k, a^k)$.

Proof: If the external source of evidence is reliable, the trust score updated with external evidence $\hat{TS}^{k+1}$ should be closer to the true trust score TS^* of the agent, as

$$|\hat{TS}^{k+1} - TS^*| \leq |TS^{k+1} - TS^*|. \quad (20)$$

For a benign user with $TS^* = 1$, receiving $h = 0$ will help improve the TS as

$$\hat{b}^{k+1}(0|s^{k+1}, a^k, d^k, h = 0) \geq b^{k+1}(0|s^{k+1}, a^k, d^k), \quad (21)$$

which yields $P_t(s^k, a^k) \geq P_f(s^k, a^k)$. Similarly, for an attacker with $TS^* = 0$, receiving $h = 1$ will help improve the TS . Equation (20) implies

$$\hat{b}^{k+1}(1|s^{k+1}, a^k, d^k, h = 1) \geq b^{k+1}(1|s^{k+1}, a^k, d^k), \quad (22)$$

which again yields $P_t(s^k, a^k) \geq P_f(s^k, a^k)$. $\square$

The reliability of the source of evidence is related to the Receiver Operating Characteristic (ROC) curve in detection literature. Ideally, we would like the evidence to be error-free where $P_t(\cdot)$ is close to 1 and $P_f(\cdot)$ is close to 0 (correctly identify the agent type without making any mistake). (0, 1) criteria are often used to compare the reliability of the detector [36]. In this work, we adopt (0, 1) criteria and propose the following.

Definition 7 (Evidence Reliability): Given the current state s^k , agent's action a^k , $P_t(s^k, a^k)$, and $P_f(s^k, a^k)$, the reliability of the source of evidence σ is defined as

$$\begin{aligned} ER_\sigma(s^k, a^k) &= \sqrt{(1 - P_t(s^k, a^k))^2 + (P_f(s^k, a^k))^2} \in [0, \sqrt{2}]. \end{aligned} \quad (23)$$

Proposition 1: Consider two sources of evidence with probability function σ_1 and σ_2 . Given s^k and a^k , the source with σ_1 is more reliable than the source with σ_2 if they satisfy

$$ER_{\sigma_1}(s^k, a^k) \leq ER_{\sigma_2}(s^k, a^k), \quad (24)$$

where the reliability ER_{σ_i} is defined in (23) for $i = 1, 2$.

$$b^{k+1}(\theta|s^{k+1}, a^k, d^k) = \frac{T(s^{k+1}|s^k, a^k, d^k, \theta)\pi_a^{*,k}(a^k|s^k, \theta)\pi_d^{*,k}(d^k|s^k)b^k(\theta|s^k)}{\sum_{\hat{\theta} \in \Theta} T(s^{k+1}|s^k, a^k, d^k, \hat{\theta})\pi_a^{*,k}(a^k|s^k, \hat{\theta})\pi_d^{*,k}(d^k|s^k)b^k(\hat{\theta}|s^k)}. \quad (15)$$

TABLE III
NETWORK VULNERABILITIES AND DEFENSE ACTIONS ON EACH EDGE

Edge	Attack technique	Attack requirement	Defense action	Vulnerability example CVE#
(1,2)	Phishing	Credentials of existing accounts	MFA on application logons	CVE-2022-41204
(2,4)	Valid account	Credentials of existing accounts	MFA on server requests	CVE-2022-35294
(1,3), (3,2), (3,5)	Unauthorized access to Network Exposure Function (NEF) via token fraud	Knowledge about accessing OAuth 2.0 tokens	Ensure NEF checks Application Function(AF) credentials across layers	CVE-2019-5625
(4,6)	Credentials from Password Stores	Credentials of existing accounts	Re-authentication and MFA	CVE-2019-1698
(2,6), (5,6)	Valid account	Privileged account credentials	Re-authentication and MFA	CVE-2022-42473
(4,5)	Remote services	Valid Account for IoT devices	MFA on remote service logons	CVE-2019-12708

Proof: The reliability ER_i is defined as the Euclidean distance between the (P_f, P_t) pair and the $(0, 1)$ point. Ideally, we aim that the false-positive rate $P_f \rightarrow 0$ and the true-positive rate $P_t \rightarrow 1$. If $ER_1 \leq ER_2$, the performance of source σ_1 is closer to the ideal point $(0, 1)$, thus producing more reliable evidence to assist the trust update. $\square$

Proposition 2: Given reliable external evidence at (s^k, a^k) and a large number of evidence observations, the evidence with high reliability ER_σ helps the TE converge faster to the true trust score TS^* .

Proof: According to Sanov's theorem [37], asymptotically the probabilities of true-positive rate P_t and false alarm P_f are

$$1 - P_t \approx 2^{-nD(B_0^*||B_1)}, \quad P_f \approx 2^{-nD(B_1^*||B_0)}, \quad (25)$$

where n is the number of i.i.d. evidence observations, B_i^* is the approximated belief distribution when $\theta = i$, B_j is the authentic type distribution when $\theta = j$, and $D(\cdot||\cdot)$ is the KL-divergence. If the evidence has higher reliability ER_σ , the (P_t, P_f) pair will be closer to the point $(0, 1)$, thus the KL-divergence value would be larger between the estimated distribution of type θ and authentic distribution of type $\neg\theta$. This means that the evidence is more likely to identify the adversarial behaviors and help the updated trust score $\hat{TS}$ to be closer to the TS^* . $\square$

VI. CASE STUDY

In this section, we provide a case study to evaluate the performance of GAZETA. 5G network can be divided into a public network that is open to any connection and a private network that is fully controlled by enterprise or government. Although the private network is composed of trusted devices, it still needs to exchange information with the public network due to external access or cloud services. If a remote agent from a public network is trying to access a critical node in the private network, it is essential to evaluate the trust of the agent before granting access. This model is critical, especially for the military tactical network connecting with cloud services. We use the following case study to show how our zero-trust framework can provide a fast and accurate trust evaluation and mitigate lateral movement from a potential attacker.

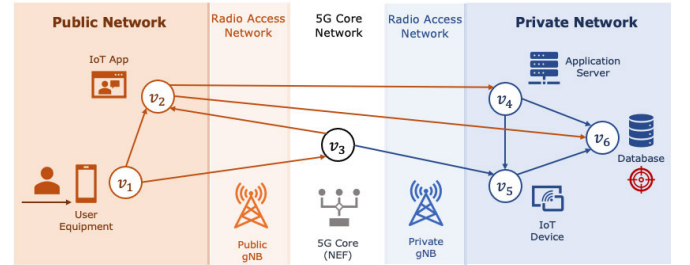


Fig. 4. Example of an authentication graph in a 5G-enabled IoT network.

A. Model Implementation

Fig. 4 presents one scenario we use to study lateral movement in such a hybrid 5G-enabled IoT environment. We assume the agent initially logs into the system using the user's equipment. The agent uses the authentication graph in Fig. 4 to try to reach the target node, i.e., the database. The attacker can use the vulnerabilities in the network to penetrate the system. This type of defense is also called end-to-end security. By securing the paths from the user to the core assets in the network, the system is protecting the entire application that could be influenced by database failures.

Table III describes the network vulnerabilities and their corresponding defense actions on each edge. The attack techniques and requirements are corresponding to MITRE FiGHT™ (5G Hierarchy of Threats) framework, which is a knowledge base of adversary tactics and techniques for 5G systems [38]. The vulnerability examples from the Common Vulnerabilities and Exposures (CVE) dictionary are used to evaluate the attack effort in the game matrices.

B. Lateral Movement Mitigation

We evaluate the performance of our model GAZETA using numerical experiments, implemented in a self-built Python simulator. We compare our model with the following access control (AC) and authentication mechanisms. The features of each method are summarized in Table IV.

- *Perimeter-based security:* a network security perimeter is built by utilizing security technologies (e.g., firewalls,

TABLE IV
DIFFERENT POLICIES AND PROPERTIES

Policy name	AuthN check	Trust	Trust update	Non-myopic trust
Perimeter-based	×	×	×	×
Random AuthN	✓	×	×	×
Static Trust AC	✓	✓	×	×
Reputation Trust AC	✓	✓	✓	×
GAZETA	✓	✓	✓	✓

virtual private networks (VPN) [39]). This architecture assumes everything inside the perimeter is trusted.

- *Random authentication*: the defender randomly sends authentication validation requests to users without considering trust. It can be considered a randomized credential lifetime.
- *Static trust access control*: the defender divides the agents into different trust levels based on certain criteria such as attribute-based access control (ABAC) [40].
- *Reputation-based trust access control*: trust evaluation is distributed at each node based on direct historical interactions or indirect recommendations from neighbors [41].

In the perimeter-based security model, both types of agents are assumed trusted and can move directly to the target. In random authentication, the system randomly selects one edge $e \in D^k$ at every stage and requests additional authentication validation. In static trust AC, both types of users are assigned with an initial fixed trust score of $TS^0 = 0.5$. This value aligns with insider threats as the static defender cannot distinguish between benign users and insiders. Similarly, in reputation-based trust AC, we assume each node begins with equal number of positive and negative experiences with both agent types ($TS^0 = 0.5$), and trust is updated in a distributed manner. Finally, in our GAZETA model, we assign $TS^0 = 0.5$ but will update TS^k dynamically as previously described. For now, we restrict the defense action to inspect only one edge at a time. The benefits of the next node $u_\theta(\cdot)$ are related to the distance to the target and the valuable information at the node. The attack effort $w(\cdot)$ is estimated via Common Vulnerability Scoring System (CVSS) [42]. We set the inspection cost $C(e) = 1$ for all edges, $\hat{m} = 1$ and $\hat{M} = 5$. Based on the settings, we simulate the access process for both types of players over 500 times and use the average total time steps $\bar{K}_\theta$ as the result.

The defense goal is to ensure system's performance with a normal user while delaying the lateral movement against a potential attacker. Ideally, in finite horizon K , we aim to let the legitimate agent $\theta = 0$ reach the target within the shortest time K_s (i.e., length of shortest path) and reject the attacker $\theta = 1$ until system credential renewal at time K . In this case study, the shortest time is $K_s = 2$, and we let the total time horizon $K = 10$. For the agent with type θ , we use the total time step $\bar{K}_\theta \in [K_s, K]$ as the metric to show the system performance.

Fig. 5 illustrates the performance comparison among different policies. In perimeter-based security, both types can

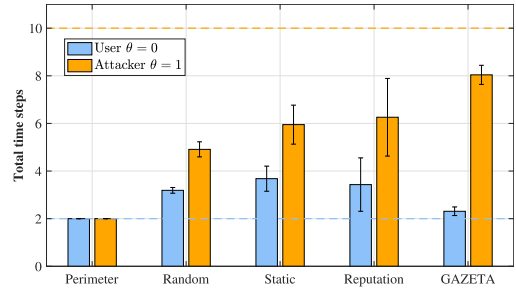


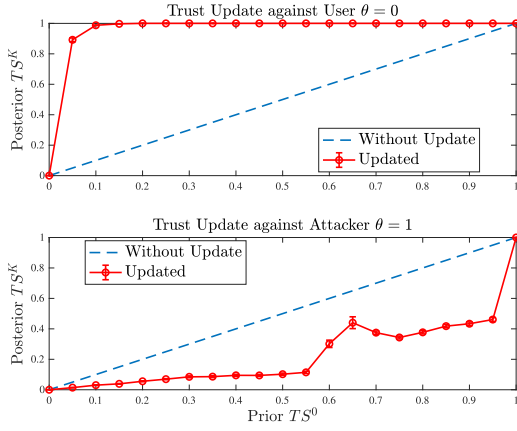
Fig. 5. Total time steps to reach the target. The dotted lines are the ideal total time steps for the agent with the same color.

reach the target with $\bar{K}_0 = \bar{K}_1 = 2$. Random authentication slightly increases the total time for the attacker to $\bar{K}_1 = 4.85$, but it fails to prevent him from reaching the target in most simulations. Static trust AC performs better than the random approach when the agent is malicious. However, it also increases the total time for the legitimate user due to equal investigation probabilities for both agent types. This will increase the operation time and degrade the system performance. Reputation-based trust AC behaves slightly better than static method, but it exhibits greater performance variance. If the attacker passes a MFA check by luck, this false observation can propagate to the neighbor nodes, creating a false sense of security. Finally, we find that GAZETA outperforms other methods under both types of agents. It can let the legitimate user quickly reach the target with $\bar{K}_0 = 2.15$ while delaying the attacker with $\bar{K}_1 = 8.04$. This indicates that the consideration of long-term interactions and dynamic trust updates in the Markov game can provide an adaptive strategy to protect the system while ensuring system performance.

C. Bayesian Trust Correction

Another important feature of GAZETA is the dynamic trust update during the interactions. We show that our dynamic trust evaluation can lead to a more reliable TS under different prior trusts. We compare the initial TS^0 and the updated posterior TS^K under two types of agents in Fig. 6. The dotted line is the baseline representing the posterior TS^K without any trust update. For a legitimate user, i.e., $\theta = 0$, the accurate estimation should yield $TS_0^* = 1$. As shown in Fig. 6, the updated TS^K is above the baseline, indicating the improvement on the trust estimation results. Even when the initial trust is significantly distant from the truth ($TS^0 \ll 1$), the trust engine is capable of rectifying erroneous priors during the course of interactions. Similarly, for an attacker with $\theta = 1$, the correct evaluation should be $TS_1^* = 0$. The updated trust exhibits temporary fluctuations on the graph but consistently remains below the baseline, bringing it closer to TS_1^* . These fluctuations occur due to the existence of multiple ϵ -PBNEs, and the algorithm does not always converge to the equilibrium that maximally benefits the defender.

These results illustrate that GAZETA leverages the potential outcomes derived from Markov games and employs Bayesian updates to provide a more reliable trust evaluation throughout the interplay. It is worth noting that at the extreme points, where the prior TS^0 equals 0 or 1, Bayesian update is

Fig. 6. Bayesian trust correction under different prior trusts TS^0 .TABLE V
DEFENSE PERFORMANCE UNDER DIFFERENT INSPECTION SCOPES

Inspection scope $ d_{max} $	Total time steps	Defense cost
1	8.04	15.24
2	9.67	32.94
3	9.87	51.31
4	9.98	62.45

ineffective due to (8). It indicates that the defender should never place 100% trust in any agent within the system, aligning with the concept of zero trust.

D. Trade-Off Between Security and Performance

We then discuss the trade-off between security investment and system performance. In our case study, the security investment relates to the defense cost (negative utility) at each stage. The defender can uniformly conduct authentication validation over every link $|d^k| = |D^k|$ or strategically inspect a few links $|d^k| < |D^k|$ that are more likely to be used by the attacker. The size of defense action $|d^k|$ influences both the protection efficiency and the total defense cost.

In this experiment, we assume the agent is malicious ($\theta = 1$) and simulate the access process over 500 times. Table V shows the defense performances under different inspection scopes. $|d_{max}|$ represents the maximum number of edges the defender would request identity validation at each stage. If the current defense action set $|D^k| \leq |d_{max}|$, the defender will inspect all links as $d^k = D^k$; otherwise, the defender can choose any subset $d^k \in D^k$ with size $|d^k| = |d_{max}|$. According to Table V, the total time steps of the attacker and defense cost will both increase as $|d_{max}|$ grows. Increasing the inspection scope would help delay the attacker but also increase the defense cost. According to the table, our model demonstrates effective performance even with a small inspection scope in this scenario. The defense cost grows at a much faster rate than the security enhancement. This discrepancy can be attributed to factors such as the network topology and the maximum time horizon K considered in the experiment. To optimize the trade-off between security and system performance, the defender must employ strategic verification methods and determine the most suitable value for $|d_{max}|$.

TABLE VI
TOTAL TIME STEPS $\bar{K}_1$ UNDER DIFFERENT CASES

Computational methods	Original $\bar{K}_1$	$\bar{K}_1$ with environment change
Offline ϵ -PBNE	8.04	5.13
Moving-horizon	7.05	6.67

E. Robust Defense With Moving-Horizon Computation

In Section V-B, we have proposed an online defense computation scheme using the moving-horizon approach. Here, we show the robustness of online defense when the network environment changes unexpectedly. We consider the case when a new edge is added to the authentication graph at stage $k = 2$ that is connecting the 5G mobile core v_3 and the database v_6 in Fig. 4. This case happens when a new application functionality joins the network and grants a group of user access to the database. If the defense policy is unable to consider this new information, the attacker can sneakily use this new route to move toward the database without additional identity validation.

In the experiments, we consider the access process of an attacker with $\theta = 1$. We set the prior trust $TS^0 = 0.5$, and the moving-horizon time span $\hat{k} = 2$. We simulate the access process with an attacker for 500 times and compare the average total time steps to reach the target using different computational methods.

Table VI illustrates the robustness of the moving-horizon defense. The first column is the original defense performance with no environmental changes. In this case, the offline ϵ -PBNE computation outperforms the moving horizon since the consideration of long-term interactions provides a better-planned security strategy. The offline computed defense becomes less effective when the new edge is added to the graph at $k = 2$ as $\bar{K}_1$ is decreasing, but the performance is improved using moving-horizon defense. With online decisions, the total steps are increased by 30% compared to offline computed defense. The system with moving-horizon defense can strategically adapt to the environment change and continue to delay the attacker.

F. Resilience With Moving-Horizon Computation

Cyber resilience concerns the response and recovery efforts once an attacker entered the system. To provide a clearer illustration of the results, we expand the authentication graph to include 10 nodes by introducing nodes in the access network with the shortest path $K_s = 4$ for legitimate users. The total time horizon considered in this scenario is $K = 15$. In our analysis, we compare the moving-horizon GAZETA model with offline defense and reputation-based trust AC, which also undergoes trust updates during the process. We initialize the system with $TS^0 = 0.9$. In reputation-based trust AC, we assume that each node in the system has 90 positive experiences and 10 negative experiences with the agent in the past and from recommendations of neighbors.

We consider an account takeover attack in which the attacker gains control of a legitimate user's account at stage $k = 2$. Fig. 7 illustrates the trust evaluation of the agent TS^k

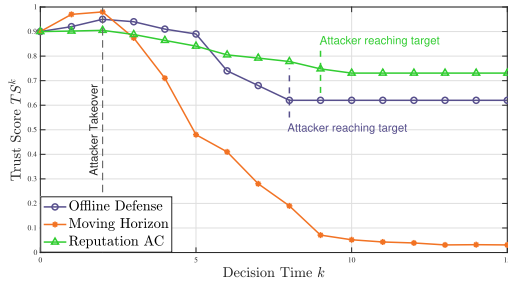


Fig. 7. Resilience in moving-horizon defense v.s. offline defense.

at each decision time $k = 0, 1, \dots, 15$ during one sampled simulation. For reputation-based trust AC, we plotted the reputation or trust score of the agent at the node making the decision at time k .

From Fig. 7, we can observe that moving-horizon defense can adapt authentication strategies more swiftly to the changes of the agent's type and discover the account takeover much faster than offline defense. In contrast, reputation-based trust evaluation can identify abnormal behavior but experiences delays due to trust propagation, resulting in a slower decrease in trust scores. The results highlight that non-myopic, in-depth trust consideration allows for a quicker understanding of the attacker's behavior and faster strategy adjustment compared to traditional trust evaluation methods. As shown in the figure, both offline defense and reputation-based trust AC fail to prevent the attacker from reaching the target, while the moving-horizon defense can deter the lateral movement successfully.

G. Trust Evaluation With Evidence

Finally, we illustrate how external source of evidence would influence dynamic trust evaluation in our model.

1) *Reliability of Evidence*: Fig. 8 illustrates the trust evaluation accuracy with different sources of evidence. We compare the initial TS^0 and the posterior $\hat{TS}^K$ updated with evidence under two types of agents. For simplicity, we assume that $P_t(s^k, a^k) = P_t$ and $P_f(s^k, a^k) = P_f$ for all $s^k \in S^k$ and $a^k \in A^k$. According to Theorem 2, a reliable source of evidence should have $P_t \geq P_f$. Under this condition, the TS score of the legitimate user should be closer to $TS_0^* = 1$ if the system receives evidence $h = 0$ and the TS score of the attacker should be closer to $TS_1^* = 0$ if the system receives evidence $h = 1$. From Fig. 8, the trust update with evidence σ_1 and σ_2 can successfully provide more accurate trust correction. However, evidence σ_1 can further push the trust evaluating closer to the authentic value since σ_1 is more reliable as $ER_1 = 0.14 \leq ER_2 = 0.73$. Fig. 8d illustrates the consequence of incorporating an unreliable source of evidence σ_3 with $P_t < P_f$. As the result, the trust evaluation with evidence σ_3 is farther from the true TS_0^* for both types of agents.

2) *Speed of Trust Convergence*: The trust update with a reliable source of evidence can also help the system identify the type of agent in shorter time steps. In the experiment, we assume the agent is an attacker with $\theta = 1$ and compare the speed of trust convergence with various sources of evidence

TABLE VII
SPEED OF TRUST CONVERGENCE

True-positive rate P_t	ER_σ	Posterior trust score $\hat{TS}^K$	Average steps to converge
0.5	0.71	0.21	4.78
0.6	0.56	0.17	3.99
0.7	0.42	0.12	3.16
0.8	0.28	0.05	2.64
0.9	0.14	0	1.02
1	0	0	1

that have different reliabilities. We assume that all evidence is reliable and satisfies $P_f = 1 - P_t$ and $P_t \geq 0.5$. Under this assumption, the evidence with higher P_t will produce smaller ER_σ and is more reliable according to Proposition 1. The prior trust is set to $TS^0 = 0.5$.

Table VII demonstrates the results. The first two columns represent the true-positive rate and ER_σ of the evidence source. The third column is the final updated trust score with evidence $\hat{TS}^K$, and the last column is the average total time steps for the trust score to converge. Experimental results illustrate that a more reliable source of evidence can have a more accurate trust evaluation with faster convergence. This indicates that more reliable evidence can help our GAZETA framework to identify the attacker and deter the penetration of lateral movement with better efficiency.

VII. DISCUSSION

Zero trust is a new security concept that is essential for modern 5G IoT networks. Both the policy engine (PE) and the trust evaluation (TE) are equally important in zero-trust architecture design. Previous studies [18], [19] in trust-related IoT security put more effort into the PE design phase and aim to find a defense policy at different levels of trust. Few works have provided discussions on how to integrate PE and TE in the design as a whole. Our work takes a holistic view and fills the gap between PE and TE by leveraging dynamic Markov games that naturally lead to interdependent PE and TE processes. The interplay between the PE and the TE helps the system form an efficient defense strategy that balances performance and security.

The primary design objective of the model is to offer a proactive zero-trust defense strategy in face of sophisticated attacks, rather than aiming for the most precise trust evaluation or the least resource-intensive trust evaluation approach. By combining PE and TE, we have demonstrated that our solution achieves end-to-end optimality. In comparison to existing trust evaluation methods like reputation-based trust, our model excels in terms of rapid adaptation and non-myopic strategies for countering attackers. While it's worth noting that exhaustive enumeration of possible game states in the GAZETA algorithm may raise scalability issues in computation, the full horizon defense policy can be precomputed offline and serve as a baseline zero-trust defense strategy. We have also introduced a moving-horizon computation method to enable online adaptation and reduce the computational burden. This online defense allows for a balanced trade-off between the accuracy

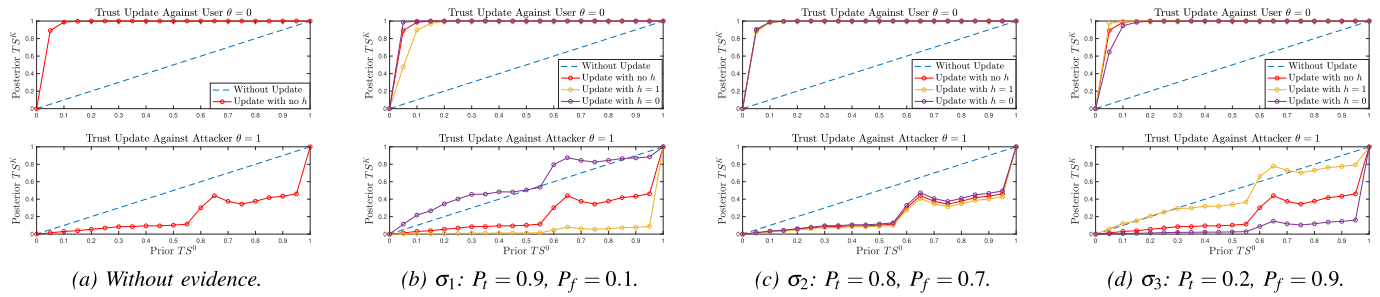


Fig. 8. Trust evaluation with different sources of evidence.

of the strategy and computational requirements. As illustrated in the experiments, online decisions with moving-horizon defense provide a more robust defense mechanism, especially in a dynamic network environment such as 5G IoT networks.

The model in our study supports further, yet to be explored, generalizations. In this work, we mainly focus on the trustworthiness of the agent's identity, but the type θ can be extended into a multi-dimensional vector that represents different aspects of trust in the system. Similarly, the evidence output h is assumed binary in our study, but we may extend it to a more comprehensive evidence space based on the underlying source of evidence that we use.

VIII. CONCLUSION

Zero-trust is an emerging security concept rooted in rigorous verification process. In this work, we have proposed a game-theoretic framework called *GAZETA* to enable quantitative trust evaluations and proactive defenses against lateral movement from potential attackers. We provide a holistic design of the policy engine and the trust evaluation by incorporating the dynamic Markov game. Compared to traditional perimeter-based defense, static trust, and reputation-based trust access control methods, *GAZETA* utilizes dynamic trust updates and strategic authentication policies to strike a balance between security and system performance. Experimental results demonstrate *GAZETA*'s superiority in security, providing the shortest access time for the legitimate user and the longest access time for the malicious attacker. It has been corroborated that our model can efficiently correct erroneous prior trust, offering a more reliable trust evaluation. Through moving-horizon computation, *GAZETA* has created a robust security model capable of adapting to unexpected environmental changes and attacks. Experimental results show that the online defense scheme can quickly discover the account takeover and deter the lateral movement of the attacker successfully. Our model facilitates a multi-source dynamic trust evaluation for 5G zero-trust security. The proposed mechanism consolidates traditional protections with zero-trust security models and provides a guide for the development of next-generation secure and resilient 5G zero-trust networks.

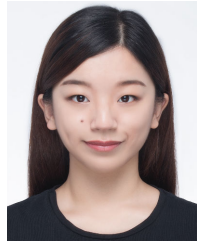
Our model enables a quantitative dynamic trust evaluation for zero-trust security. Based on the trust evaluation, defenders can further find tailored countermeasures to achieve an optimal trade-off between security and usability. Our model can be

broadly applied to other zero-trust defense mechanisms of similar nature.

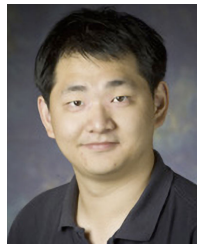
REFERENCES

- [1] N. Lal, S. M. Tiwari, D. Khare, and M. Saxena, "Prospects for handling 5G network security: Challenges, recommendations and future directions," *J. Phys., Conf. Ser.*, vol. 1714, no. 1, Jan. 2021, Art. no. 012052.
- [2] Q. Zhu, S. Rass, B. Dieber, and V. M. Vilches, "Cybersecurity in robotics: Challenges, quantitative modeling, and practice," 2021, *arXiv:2103.05789*.
- [3] T. Weil and S. Murugesan, "IT risk and resilience—Cybersecurity response to COVID-19," *IT Prof.*, vol. 22, no. 3, pp. 4–10, May 2020.
- [4] A. Patel, Q. Qassim, and C. Wills, "A survey of intrusion detection and prevention systems," *Inf. Manage. Comput. Secur.*, vol. 18, no. 4, pp. 277–290, Oct. 2010.
- [5] I. Homoliak, F. Toffalini, J. Guarnizo, Y. Elovici, and M. Ochoa, "Insight into insiders and IT: A survey of insider threat taxonomies, analysis, modeling, and countermeasures," *ACM Comput. Surv.*, vol. 52, no. 2, pp. 1–40, Mar. 2020.
- [6] Q. Zhu and S. Rass, "On multi-phase and multi-stage game-theoretic modeling of advanced persistent threats," *IEEE Access*, vol. 6, pp. 13958–13971, 2018.
- [7] J. Suomalainen, J. Julku, M. Vehkaperä, and H. Posti, "Securing public safety communications on commercial and tactical 5G networks: A survey and future research directions," *IEEE Open J. Commun. Soc.*, vol. 2, pp. 1590–1615, 2021.
- [8] V. Stafford, *Zero Trust Architecture*, Standard NIST SP 800-207, 2020.
- [9] E. Gilman and D. Barth, *Zero Trust Networks*. Sebastopol, CA, USA: O'Reilly Media, 2017.
- [10] L. Huang and Q. Zhu, "A dynamic games approach to proactive defense strategies against advanced persistent threats in cyber-physical systems," *Comput. Secur.*, vol. 89, Feb. 2020, Art. no. 101660.
- [11] Y. Ge and Q. Zhu, "MUFZA: Multi-source fast and autonomous zero-trust authentication for 5G networks," in *Proc. IEEE Mil. Commun. Conf. (MILCOM)*, Nov. 2022, pp. 571–576.
- [12] H.-J. Liao, C.-H. R. Lin, Y.-C. Lin, and K.-Y. Tung, "Intrusion detection system: A comprehensive review," *J. Netw. Comput. Appl.*, vol. 36, no. 1, pp. 16–24, 2013.
- [13] D. R. Miller, *Security Information and Event Management (SIEM) Implementation*. New York, NY, USA: McGraw-Hill, 2011.
- [14] R. Ward and B. Beyer, "BeyondCorp: A new approach to enterprise security," *Login*, vol. 39, no. 6, pp. 6–11, 2014.
- [15] J. Li et al., "CyberGuarder: A virtualization security assurance architecture for green cloud computing," *Future Gener. Comput. Syst.*, vol. 28, no. 2, pp. 379–390, Feb. 2012.
- [16] Y. Tao, Z. Lei, and P. Ruxiang, "Fine-grained big data security method based on zero trust model," in *Proc. IEEE 24th Int. Conf. Parallel Distrib. Syst. (ICPADS)*, Dec. 2018, pp. 1040–1045.
- [17] L. Xiao, X. Wan, X. Lu, Y. Zhang, and D. Wu, "IoT security techniques based on machine learning: How do IoT devices use AI to enhance security?" *IEEE Signal Process. Mag.*, vol. 35, no. 5, pp. 41–49, Sep. 2018.
- [18] Y. B. Saied, A. Olivereau, D. Zeghlache, and M. Laurent, "Trust management system design for the Internet of Things: A context-aware and multi-service approach," *Comput. Secur.*, vol. 39, pp. 351–365, Nov. 2013.

- [19] M. Samaniego and R. Deters, "Zero-trust hierarchical management in IoT," in *Proc. IEEE Int. Congr. Internet Things (ICIOT)*, Jul. 2018, pp. 88–95.
- [20] D. Basin, J. Dreier, L. Hirschi, S. Radomirovic, R. Sasse, and V. Stettler, "A formal analysis of 5G authentication," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, Oct. 2018, pp. 1383–1396.
- [21] J. Zhang, L. Yang, W. Cao, and Q. Wang, "Formal analysis of 5G EAP-TLS authentication protocol using proverif," *IEEE Access*, vol. 8, pp. 23674–23688, 2020.
- [22] J. Ni, X. Lin, and X. S. Shen, "Efficient and secure service-oriented authentication supporting network slicing for 5G-enabled IoT," *IEEE J. Sel. Areas Commun.*, vol. 36, no. 3, pp. 644–657, Mar. 2018.
- [23] X. Jia, N. Hu, S. Yin, Y. Zhao, C. Zhang, and X. Cheng, "A2 chain: A blockchain-based decentralized authentication scheme for 5G-enabled IoT," *Mobile Inf. Syst.*, vol. 2020, pp. 1–19, Dec. 2020.
- [24] B. Bowman, C. Laprade, Y. Ji, and H. H. Huang, "Detecting lateral movement in enterprise computer networks with unsupervised graph AI," in *Proc. 23rd Int. Symp. Res. Attacks, Intrusions Defenses (RAID)*, 2020, pp. 257–268.
- [25] P.-Y. Chen, S. Choudhury, L. Rodriguez, A. Hero, and I. Ray, "Enterprise cyber resiliency against lateral movement: A graph theoretic approach," 2019, *arXiv:1905.01002*.
- [26] M. A. Nouredine, A. Fawaz, W. H. Sanders, and T. Başar, "A game-theoretic approach to respond to attacker lateral movement," in *Proc. 7th Int. Conf. Decis. Game Theory Secur. (GameSec)*, New York, NY, USA, vol. 9996, Berlin, Germany: Springer-Verlag, 2016, pp. 294–313, doi: [10.1007/978-3-319-47413-7_17](https://doi.org/10.1007/978-3-319-47413-7_17).
- [27] I. Ahmad, S. Shahabuddin, T. Kumar, J. Okwuibe, A. Gurtov, and M. Ylianttila, "Security for 5G and beyond," *IEEE Commun. Surveys Tuts.*, vol. 21, no. 4, pp. 3682–3722, 4th Quart., 2019.
- [28] K. Ramezani and J. Jagannath, "Intelligent zero trust architecture for 5G/6G networks: Principles, challenges, and the role of machine learning in the context of O-RAN," *Comput. Netw.*, vol. 217, Nov. 2022, Art. no. 109358.
- [29] Y. Ge and Q. Zhu, "Trust threshold policy for explainable and adaptive zero-trust defense in enterprise networks," in *Proc. IEEE Conf. Commun. Netw. Secur. (CNS)*, Oct. 2022, pp. 359–364.
- [30] Y. Ge, T. Li, and Q. Zhu, "Scenario-agnostic zero-trust defense with explainable threshold policy: A meta-learning approach," in *Proc. IEEE Conf. Comput. Commun. Workshops (INFOCOM WKSHPS)*, May 2023, pp. 1–6.
- [31] B. C. Neuman and T. Ts'o, "Kerberos: An authentication service for computer networks," *IEEE Commun. Mag.*, vol. 32, no. 9, pp. 33–38, Sep. 1994.
- [32] D. Hardt, "The OAuth 2.0 authorization framework," RFC Ed., RFC 6749, Oct. 2012. [Online]. Available: <https://www.rfc-editor.org/info/rfc6749>, doi: [10.17487/RFC6749](https://doi.org/10.17487/RFC6749).
- [33] A. Ometov, S. Bezzateev, N. Mäkitalo, S. Andreev, T. Mikkonen, and Y. Koucheryav, "Multi-factor authentication: A survey," *Cryptography*, vol. 2, no. 1, p. 1, Jan. 2018.
- [34] Q. Liu et al., "Latte: Large-scale lateral movement detection," in *Proc. IEEE Mil. Commun. Conf. (MILCOM)*, Oct. 2018, pp. 1–6.
- [35] J. B. Cruz, M. A. Simaan, A. Gacic, and Y. Liu, "Moving horizon Nash strategies for a military air operation," *IEEE Trans. Aerosp. Electron. Syst.*, vol. 38, no. 3, pp. 989–999, Jul. 2002.
- [36] I. Unal, "Defining an optimal cut-point value in ROC analysis: An alternative approach," *Comput. Math. Methods Med.*, vol. 2017, pp. 1–14, May 2017.
- [37] M. Thomas and A. T. Joy, *Elements of Information Theory*. Hoboken, NJ, USA: Wiley, 2006.
- [38] MITRE. (2022). *Fight*. Accessed: Nov. 7, 2022. [Online]. Available: <https://fight.mitre.org/>
- [39] S. Ioannidis, A. D. Keromytis, S. M. Bellovin, and J. M. Smith, "Implementing a distributed firewall," in *Proc. 7th ACM Conf. Comput. Commun. Secur.*, Nov. 2000, pp. 190–199.
- [40] V. C. Hu, D. R. Kuhn, D. F. Ferraiolo, and J. Voas, "Attribute-based access control," *Computer*, vol. 48, no. 2, pp. 85–88, Feb. 2015.
- [41] Z. Wei, H. Tang, F. R. Yu, M. Wang, and P. Mason, "Security enhancements for mobile ad hoc networks with trust management using uncertain reasoning," *IEEE Trans. Veh. Technol.*, vol. 63, no. 9, pp. 4647–4658, Nov. 2014.
- [42] S. H. Houmb and V. N. L. Franqueira, "Estimating ToE risk level using CVSS," in *Proc. Int. Conf. Availability, Rel. Secur.*, Mar. 2009, pp. 718–725.



Yunfei Ge (Graduate Student Member, IEEE) received the B.S. degree (Hons.) in optoelectronics from Sun Yat-sen University (SYSU), Guangzhou, China, in 2017, and the M.S. degree in electrical engineering from Columbia University, New York, NY, USA, in 2019. She is currently pursuing the Ph.D. degree in electrical engineering with New York University, New York. Her current research interests include game theory, multi-agent decision-making, cybersecurity, and accountability in AI systems. She was a recipient of the Honors Thesis Award for undergraduate studies from SYSU and the David C. and Cecilia M. Chang Education Award for graduate teaching excellence in electrical and computer engineering from the Tandon School of Engineering, NYU.



Quanyan Zhu (Senior Member, IEEE) received the B.Eng. degree (Hons.) in electrical engineering from McGill University in 2006, the M.A.Sc. degree from the University of Toronto in 2008, and the Ph.D. degree from the University of Illinois at Urbana-Champaign (UIUC) in 2013. After stints at Princeton University, he is currently an Associate Professor with the Department of Electrical and Computer Engineering, New York University (NYU), where he is an Affiliated Faculty Member with the Center for Urban Science and Progress (CUSP). He is the coauthor of two recent books published by Springer: *Cyber-Security in Critical Infrastructures: A Game-Theoretic Approach* (with S. Rass, S. Schauer, and S. König) and *A Game- and Decision-Theoretic Approach to Resilient Interdependent Network Analysis and Design* (with J. Chen). His current research interests include game theory, machine learning, cyber deception, network optimization and control, smart cities, the Internet of Things, and cyber-physical systems. He was a recipient of many awards, including the NSF CAREER Award, the NYU Goddard Junior Faculty Fellowship, the NSERC Postdoctoral Fellowship (PDF), the NSERC Canada Graduate Scholarship (CGS), and the Mavis Future Faculty Fellowships. He spearheaded and chaired the INFOCOM Workshop on Communications and Control on Smart Energy Systems (CCSES), the Midwest Workshop on Control and Game Theory (WCGT), and the ICRA workshop on Security and Privacy of Robotics. He served as the General Chair or the TPC Chair for the Seventh and the 11th Conference on Decision and Game Theory for Security (GameSec) in 2016 and 2020, the Ninth International Conference on Network Games, Control and Optimization (NETGCOOP) in 2018, the Fifth International Conference on Artificial Intelligence and Security (ICAIS 2019) in 2019, and the 2020 IEEE Workshop on Information Forensics and Security (WIFS). He also spearheaded the IEEE Control System Society (CSS) Technical Committee on Security, Privacy, and Resilience, in 2020.